

ShipShape Audit — Findings Summary

Phase 1 (Diagnosis) · branch shipshape/audit · 7/7 categories baselined · companion to AUDIT_REPORT.md · each table uses the PRD's prescribed metrics per category

Condition of record (all baselines): documents=577, issues=328, sprints=35, users=31 (pnpm db:seed + seed-augment.sql, deterministic). Node v20.20.2 · PostgreSQL 16 (Docker) · macOS aarch64. Every number is produced by a committed re-runnable script in scripts/audit/ → raw in docs/audit/raw/; Phase-2 re-runs the same scripts for before/after. **Data-safety:** pnpm --filter @ship/api test truncates ship_dev.

1 — Type Safety measured

TypeScript Compiler API AST walk (no linter in repo; strict ON). Scope A = non-test src. → cat1-type-safety.mjs

Total any types	94 (api 65 · web 29 · shared 0)
Total type assertions (as)	433 (api 135 · web 298 · shared 0)
Total non-null assertions (!)	325 (api 292 · web 33 · shared 0)
Total @ts-ignore / @ts-expect-error	0 (1 in tests only)
Strict mode enabled?	Yes (strict + noUncheckedIndexedAccess + noImplicitReturns + noFallthroughCasesInSwitch; web tsconfig omits last 3)
Strict mode error count (if disabled)	N/A (strict enabled)
Top 5 violation-dense files	weeks.ts (84) · projects.ts (51) · issues.ts (48) · UnifiedDocumentPage.tsx (37) · seed.ts (35)

Aggregate = 852 violations; PRD Improvement Target "eliminate 25%" ⇒ ≤ 639 (−213).

- 1. **High** — non-null ! (325, api 292) is the dominant risk class.
- 2. **High** — as (433, web 298): downstream loss of discriminated-union narrowing.
- 3. **Medium** — explicit any (94) in api routes; **no linter** guards new violations.

2 — Bundle Size measured

Production vite build --sourcemap + sourcemap byte attribution. → cat2-bundle.mjs

Total production bundle size	2,275 KB raw / 695.5 KB gzip (JS 2,210 / CSS 65)
Largest chunk (name + size)	index-C2vAyoQ1.js — 2,025 KB raw / 575.7 KB gzip
Number of chunks	261 JS + 1 CSS — but 91.6% of all JS is in that one chunk
Top 3 largest dependencies	emoji-picker-react (~398 KB, 7.8%) · highlight.js (~376 KB, 7.4%) · react-router (~347 KB, 6.8%)
Unused dependencies identified	@tanstack/query-sync-storage-persister (candidate — verify)

Code splitting (PRD "How to Measure"): minimal — 3 React.lazy; tab chunks 1–16 KB; everything else monolithic. PRD Improvement Target = −15% total or −20% initial via splitting.

- 1. **High** — monolithic entry chunk (576 KB gzip, 91.6% of JS); no route/vendor split.
- 2. **High** — editor-only deps (highlight.js, emoji-picker) ship on first load; lazy-load = large low-risk win.

3 — API Response Time measured

Dependency-free concurrent-load harness, API :3000 direct, warmup=10/budget=120/cell @ concurrency 10-25-50 (headline @25). → cat3-api.mjs

Endpoint (key flow) @conc 25	P50	P95	P99
GET /api/documents?document_type=wiki (main page, ~300 KB)	163ms	201ms	211ms
GET /api/issues (list issues, ~280 KB, 328 rows)	101ms	124ms	130ms
GET /api/weeks (sprint board)	20ms	25ms	27ms
GET /api/search/mentions?q=load (search)	16ms	20ms	21ms
GET /api/documents/:id (view document)	18ms	23ms	26ms

Concurrency tested 10/25/50, 0 errors all cells. P95 scales ~linearly on the slow two: main_page 100→201→**362ms**, list_issues 63→124→**222ms**.

1. **High** — two unbounded list endpoints dominate & degrade ~linearly; SQL <1.5 ms ⇒ cost = serializing 300/280 KB JSON on the shared event loop.
2. **Medium** — global rate limiter **100 req/min prod**; per-request session write on every endpoint.

4 — Database Query Efficiency measured

Postgres full statement logging; 5 marker-bracketed flows, API-pool PIDs only. → cat4-db.mjs

User Flow	Total Queries	Slowest (ms)	N+1?
Load main page /api/documents?type=wiki	4	1.419	No
View a document /api/documents/:id	4	0.214	No
List issues /api/issues	5	0.985	No
Load sprint board /api/weeks	5	0.227	No
Search content /api/search/mentions	5	0.433	No

EXPLAIN: main_page exec 0.144 ms / planning 0.561 ms; purpose-built partial index unused at this volume.

1. **High** — universal auth tax: every flow runs `SELECT sessions + UPDATE sessions.last_activity` — 2 of every 4–5 queries are auth overhead.
2. **Medium** — no pagination/LIMIT; grows linearly with workspace size. **Low** — well-indexed, no N+1.

5 — Test Coverage & Quality measured

Unit run 3× for flakiness; E2E static catalog; coverage attempted. → docs/audit/raw/cat5-before.txt

Total tests	451 unit (api, 28 files) + ~882 E2E across 71 spec files (static count)
Pass / Fail / Flaky	unit: 451 / 0 / 0 (3 runs identical — stable). E2E: not obtainable
Suite runtime	unit: ~15–16 s (16/15/16). E2E: not obtainable
Critical flows with zero coverage	document CRUD via HTTP, auth, real-time Yjs collaboration; 16 web unit files never run by <code>pnpm test</code>
Code coverage % (if measured)	web: n/a (no coverage config) / api: n/a (@vitest/coverage-v8 not installed) — unmeasurable as-shipped

1. **High** — mandated /e2e-test-runner skill **does not exist**; 882-test suite unrunnable by sanctioned method.
2. **High** — coverage unmeasurable as-shipped. **Positive** — unit layer stable & fast.

6 — Runtime Errors & Edge Cases

measured

Reproducible Playwright harness: console · malformed input · RT1 collab (validated control) · slow-3G · PG log. → cat6-runtime.mjs

Console errors during normal usage	0 across all 6 pages (0 console.error / pageerror / failed req / ≥500)
Unhandled promise rejections (server)	Not directly observable (no centralized API logging); proxy: 1 Postgres ERROR (the bad-UUID 500); 0 browser 5xx in normal nav
Network disconnect recovery	Pass — online control PERSISTED; transient disconnect (tab open) PERSISTED; Yjs IndexedDB offline store present
Missing error boundaries	None triggered in normal use (0 pageerrors); fault-injection not exercised this pass
Silent failures identified	text/plain body → 201 creates a default doc; + RT1/RT3 server-side swallowed persist

Malformed-input matrix: bad JSON → 400 HTML stack page · missing CSRF → 403 HTML stack · oversized title → 400 clean JSON · wrong content-type → 201 · bad UUID path → 500 + raw PG error

1. **High** — unvalidated path params → raw DB error as 500; bad-JSON/missing-CSRF leak HTML stack traces (inconsistent contract).
2. **Medium** — no Content-Type guard (silent doc creation). **RT1 honestly downgraded**: client offline path robust; residual = server-side swallowed persist.

7 — Accessibility

measured

axe-core WCAG 2.1 A+AA + keyboard/contrast/landmark, validated by an unauthenticated login control. (Lighthouse not a repo dep — axe used; honest substitution.) → cat7-ally.mjs

Lighthouse accessibility score (per page)	<i>Lighthouse not a repo dep — axe-core substituted (honest)</i> : violations/passes — login 0/23 · main_docs 2/22 · view_document 2/22 · issues 0/21 · my_week 1/20 · team_dir 0/20
Total Critical/Serious violations	Critical = 2, Serious = 17 node instances (C+S = 19); 3 rules: aria-required-children, listitem, color-contrast
Keyboard navigation completeness	Broken (authenticated) — only 3 distinct focusable in 60 Tabs vs 4/4 login control, despite 369–1017 interactive els
Color contrast failures	15 nodes, all on /my-week (low-opacity muted text) — WCAG 1.4.3 AA
Missing ARIA labels or roles	aria-required-children (critical) + listitem (serious) on main_docs & view_document; login lacks main/nav landmarks; lang/title/single-h1 OK

README "Section 508 / WCAG 2.1 AA compliant" claim → **CONTRADICTED** by the evidence above (automated scan = lower bound).

1. **High** — keyboard navigation broken on the authenticated app (WCAG 2.1.1/2.4.3, core 508).
2. **High** — README 508/WCAG-AA claim false as shipped. **Positive** — baseline hygiene solid; failures localized.

Three strongest Phase-2 candidates (map to the deck's measurable ≥20% targets, each independently reproducible & low-blast-radius):

(1) paginate the two heavy list endpoints → P95 drop on ≥2 endpoints (cat3-api.mjs). (2) throttle the per-request last_activity write → fewer queries on ≥1 flow (cat4-db.mjs). (3) code-split + lazy-load editor-only deps → smaller initial bundle (cat2-bundle.mjs).

Phase-1 gate: **7 / 7 categories baselined**; each table mirrors the PRD's prescribed metrics for that category. Full methodology, raw evidence, and the cross-category ranked findings summary (High/Medium/Low + reproduction) live in AUDIT_REPORT.md. No application code was changed during the audit — only reproducible measurement instruments and deterministic test data.